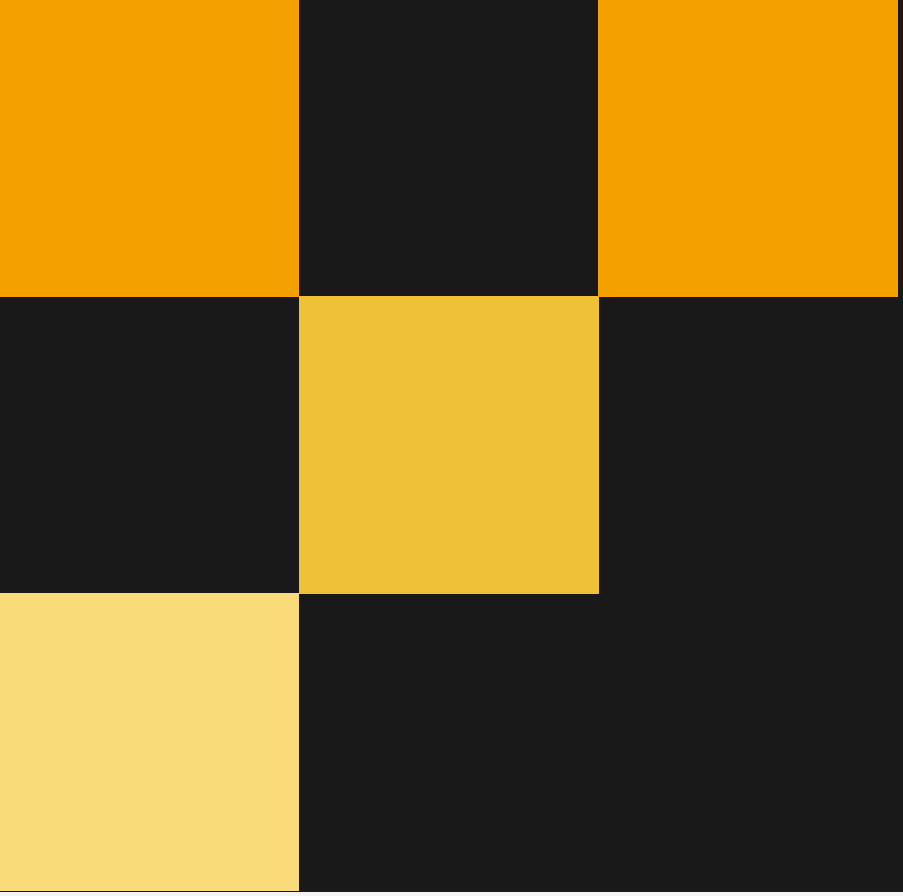


Vulnerabilidades de memória Non-Volatile

Pedro Webber

Tópicos

- Introdução
- Contextualização histórica
- Conceitos de memória Non-Volatile
- Vulnerabilidades
- Ameaças – Exemplos
- Demonstração



O que é memória Non-volatile

Memória que persiste
mesmo sem energia

Exemplos

- SPI Flash EEPROM
- SSD
- HDD
- NVRAM
- Óptica

Contextualização Histórica

Anos 80-90	BIOS Simples, Sem segurança, texto-claro
2005	Surgimento do UEFI, arquitetura mais robusta
2012+	Secure Boot, TPM, mitigação de ataques físicos e de firmware
Hoje	Ataques sofisticados contra firmware ainda são usados por APTs



Arquitetura de NVM

Firmware:

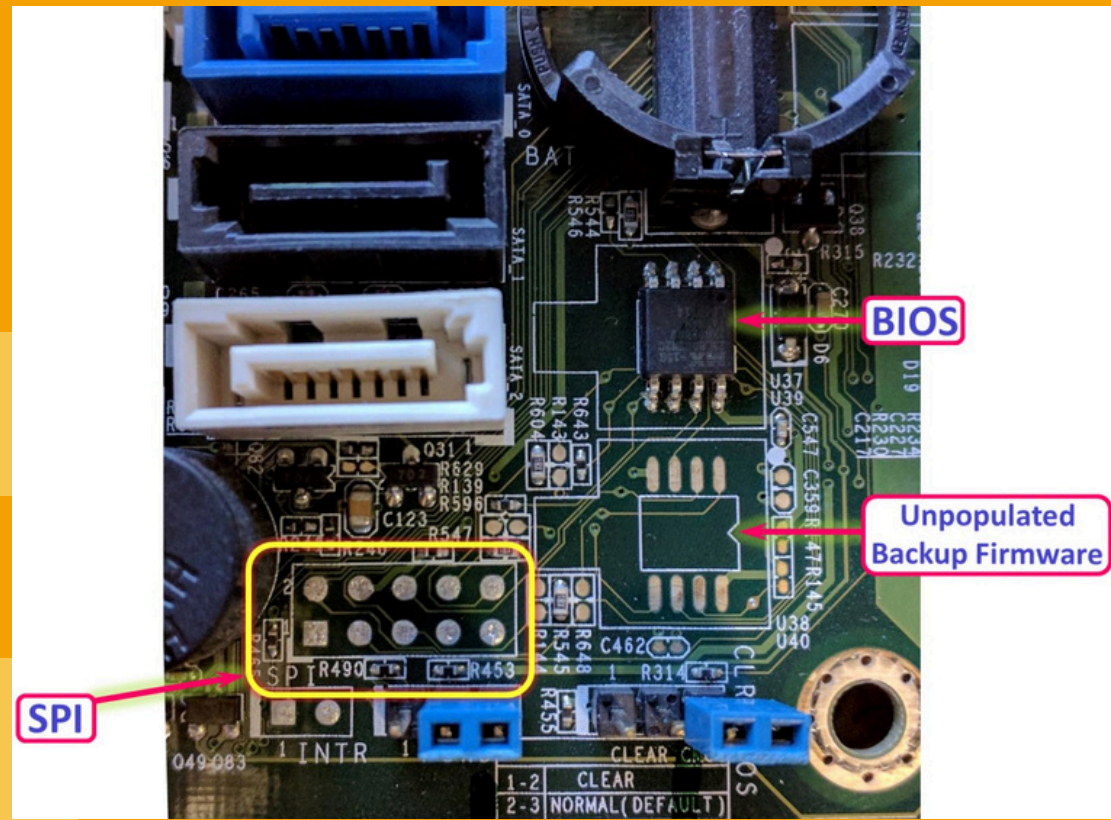
- SPI Flash EEPROM: Firmware da BIOS/UEFI → chip soldado na placa-mãe.
- NVRAM: Guarda variáveis persistentes da UEFI (Secure Boot, configurações).
- EEPROMs em periféricos: Firmware de SSDs, placas de rede, GPUs, controladores USB, etc.

Componentes Críticos

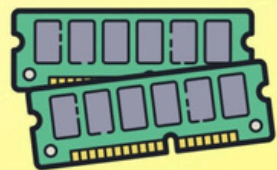
- UEFI Firmware:
 - Fases:
 - SEC → Inicialização mínima e segurança inicial
 - PEI → Inicializa memória RAM e detecta hardware
 - DXE → Carrega drivers, runtime e segurança
 - BDS → Seleção de dispositivo de boot
- Firmware de Periféricos:
 - SSD, NIC, GPU, controladores USB → todos tem memória Non-Volatile embarcada.

Vulnerabilidades

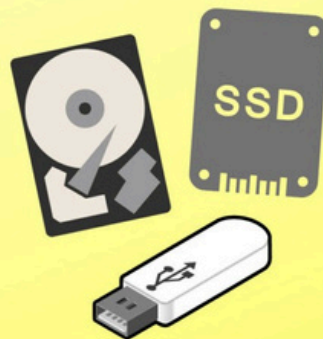
- Firmware inseguro ou sem assinatura digital.
- Falhas na proteção contra gravação (WP – Write Protection desabilitada).
- Ataques físicos (programadores de EEPROM, acesso SPI).
- Ataques remotos (via malware com privilégios de kernel).
- Persistência de rootkits em UEFI.



Volatile memory



Non-volatile Memory

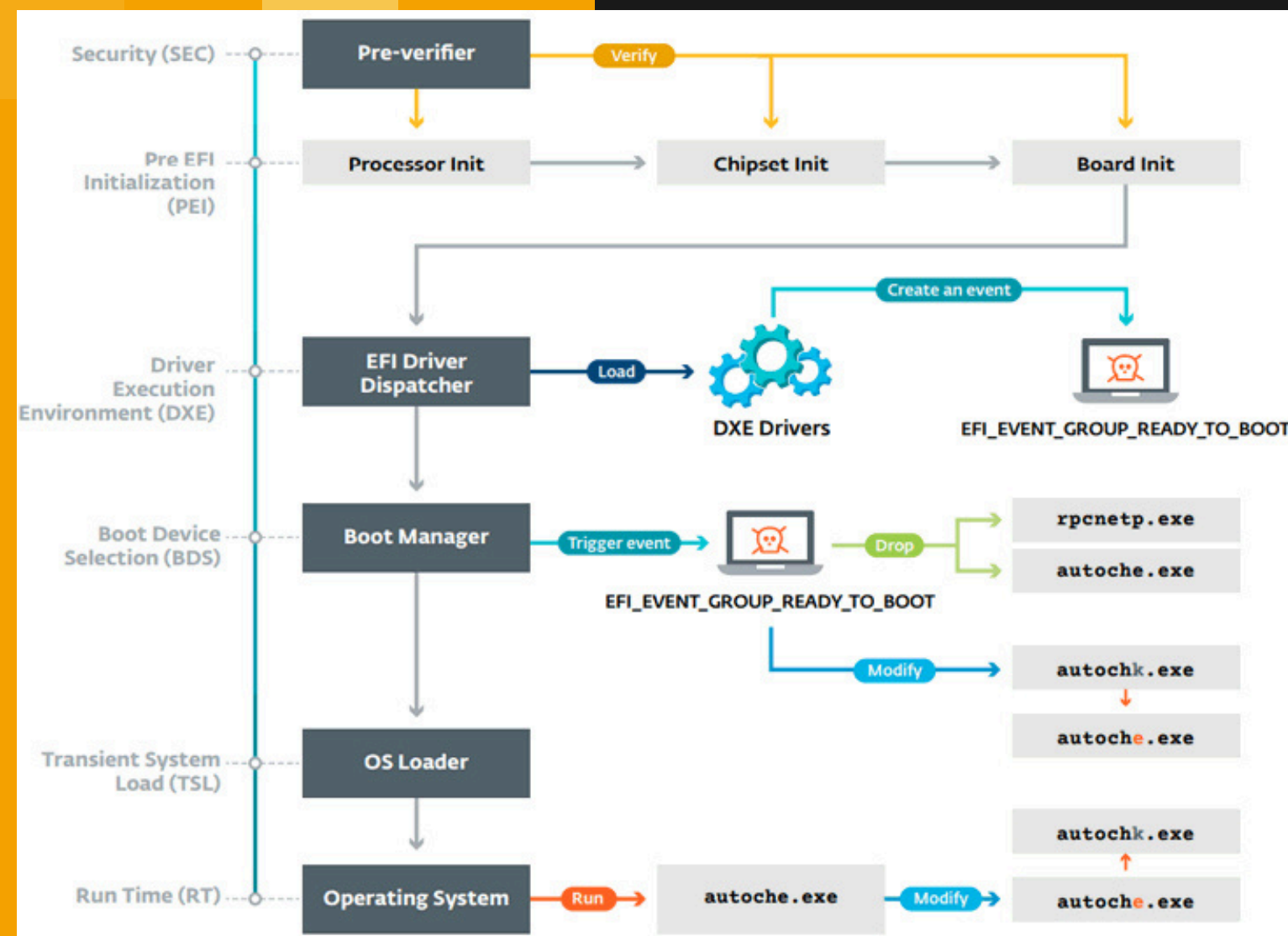


Exemplos – Ameaças

LoJax (2018) – UEFI Rootkit

- Primeiro rootkit UEFI detectado.
- Persistência no firmware UEFI (SPI Flash).
- Persistência mesmo após formatação e troca de HD.
- Associado ao grupo APT 28 (Fancy Bear)

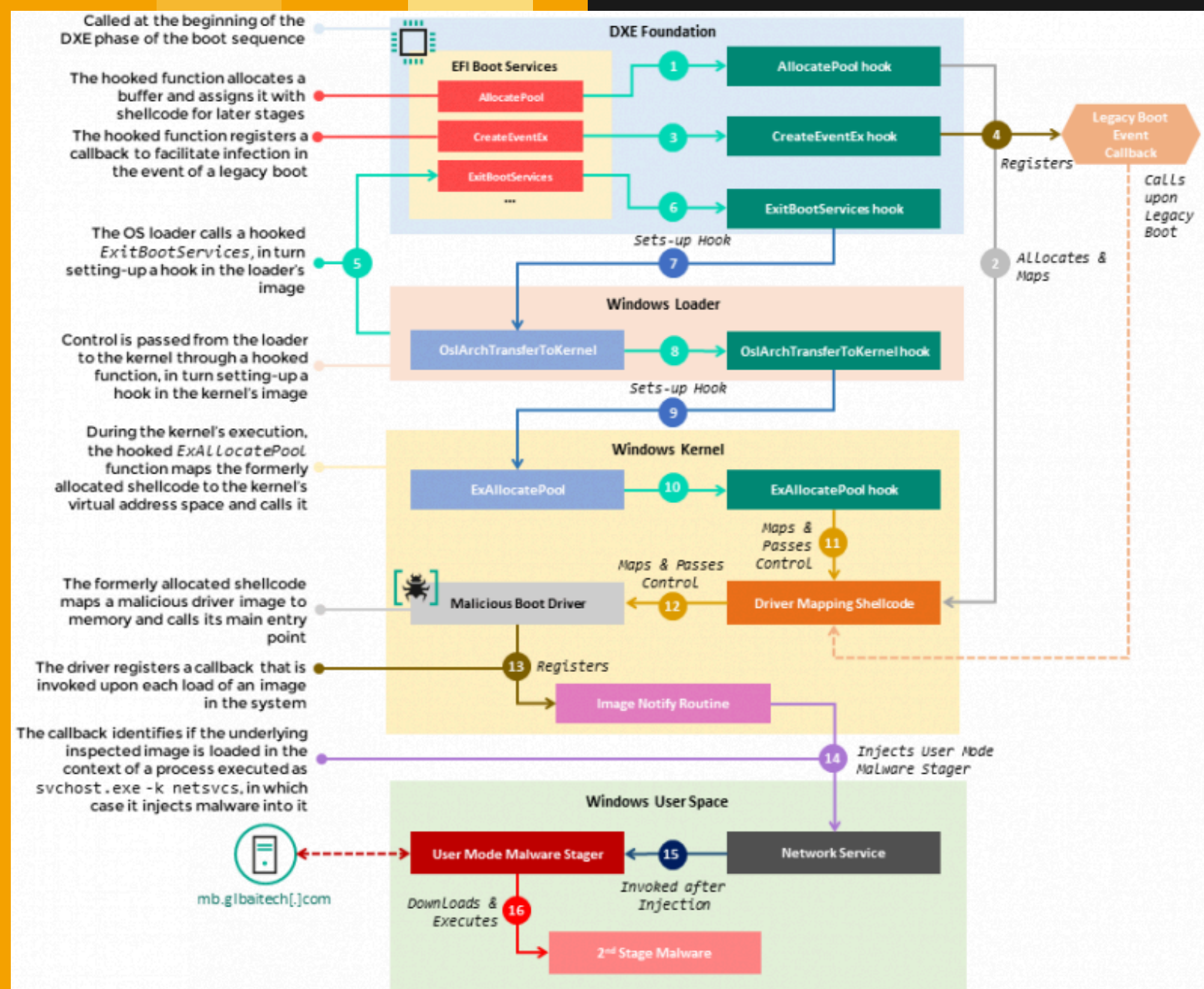
- **T1542.001 – Pre-OS Boot: System Firmware**
 - Modificação da UEFI/BIOS para ganhar persistência antes da inicialização do sistema operacional.
- **T1562.001 – Impair Defenses: Disable or Modify Tools**
 - Desativa proteções como Secure Boot ou altera firmware para burlar verificações.
- **T1078 – Valid Accounts**
 - Necessita acesso inicial com privilégios de administrador/root para escrever na SPI Flash
- **T1601.001 – Modify System Image: Boot Image (Overlap)**
 - Modificação de imagens de boot (ligado à alteração da cadeia de inicialização).



Exemplos – Ameaças

MoonBounce(2022) – UEFI Firmware implant

- Malware totalmente residente no firmware UEFI, implantado na SPI Flash, sem depender de arquivos no disco.
- Credencial stealer que contata uma infraestrutura de C2 após o boot
- Associado a APT41 (Wicked Panda)



- **T1542.001 — Pre-OS Boot: System Firmware**
 - Persistência total na SPI Flash. Executa antes do SO.
- **T1542.004 — Pre-OS Boot: Bootkit**
 - Modifica a cadeia de boot para carregar payloads maliciosos.
- **T1003.005 — OS Credential Dumping: Security Account Manager (SAM) (Pós-boot)**
 - Após a inicialização, captura credenciais no Windows.
- **T1059 — Command and Scripting Interpreter (Pós-comprometimento)**
 - Executa comandos no sistema operacional após a carga maliciosa.

Demonstração

- Confirm-SecureBootUEFI
- Get-ItemProperty -Path HKLM:
\\SYSTEM\\CurrentControlSet\\Control\\SecureBoot\\State
- Get-WmiObject -Namespace root\\wmi -Class MSSmBios_RawSMBiosTables
→ informações de firmware
- Get-Tpm → informações sobre o TPM
- bcdedit /enum all → configurações de boot